

SOP – Security Incident Response (CFlux)

Version: 1.0 · Stand: 2026-07-13 · Verantwortlich: Security-Verantwortlicher / IT-Betrieb

Regelt Erkennung, Eindämmung, Behebung und Nachbereitung von Sicherheitsvorfällen in der CFlux-Umgebung.

1. Zweck & Geltungsbereich

Strukturiertes, schnelles Vorgehen bei Sicherheitsvorfällen, um Schaden zu begrenzen, Beweise zu sichern und Melde-/Datenschutzpflichten einzuhalten.

Beispiele für Vorfälle: kompromittiertes Admin-Konto, geleaktes Secret (**JWT_SECRET**, DB-Passwort, Action1-Token), unbefugter DB-Zugriff, Schadsoftware auf dem Host, Datenabfluss, verdächtige Massen-Logins.

2. Rollen & Alarmierung

Rolle	Aufgabe
Erstkontakt (Bereitschaft/Admin)	Vorfall aufnehmen, Erstbewertung, eskalieren
Incident Lead	Koordination, Entscheidungen, Kommunikation
Datenschutzverantwortlicher	Bewertung Meldepflicht (bei Personendaten)
Geschäftsleitung	Freigabe externer Kommunikation

Kontakte/Erreichbarkeit hier eintragen: _____.

3. Klassifizierung (Severity)

- **Kritisch (P1):** Aktiver Datenabfluss, Ransomware, Admin-Kompromittierung, Produktivausfall.
- **Hoch (P2):** Geleaktes Secret, unbefugter Zugriff ohne bestätigten Datenabfluss.
- **Mittel/Niedrig (P3/P4):** Verdachtsfälle, Fehlkonfiguration ohne Ausnutzung.

4. Ablauf (6 Phasen)

4.1 Erkennen & Melden

- Auffälligkeit (Logs, Meldung, Monitoring) dokumentieren: Zeit, Beobachtung, Quelle.
- Incident Lead informieren, Severity festlegen, **Incident-Ticket** eröffnen.

4.2 Eindämmen (Containment)

- Kompromittiertes **Konto sofort deaktivieren** (SOP Benutzer- & Zugriffsverwaltung).
- Bei Verdacht auf Token-Missbrauch: **JWT_SECRET rotieren** → invalidiert alle Sessions.

```
# In .env neuen starken Wert setzen, dann:  
docker-compose up -d backend
```

- Bei P1 ggf. System vom Netz nehmen / Frontend stoppen:

```
docker-compose stop frontend backend
```

- **Beweise sichern, bevor bereinigt wird** (siehe 4.6): Logs/Volumes nicht überschreiben.

4.3 Beweissicherung

```
# Logs sichern  
docker-compose logs --no-color > incident_logs_$(date +%F_%H%M).txt  
# DB-Schnappschuss (forensisch, vor Änderungen)  
docker exec timetracking-db pg_dump -U timetracking -d timetracking -F c -f  
/tmp/incident.dump  
docker cp timetracking-db:/tmp/incident.dump ./incident_$(date +%F).dump
```

- Zeitstempel, betroffene Konten, IPs, Auffälligkeiten festhalten.

4.4 Beheben (Eradication)

- Ursache beseitigen (Schwachstelle patchen, Fehlkonfiguration korrigieren).
- **Alle betroffenen Secrets rotieren:** `JWT_SECRET`, `POSTGRES_PASSWORD`, Action1-Token, betroffene Benutzer-Passwörter (Reset erzwingen).
- Schadsoftware/Manipulationen entfernen; ggf. aus sauberem Stand neu aufsetzen.

4.5 Wiederherstellen (Recovery)

- Aus **verifiziert sauberem** Backup wiederherstellen (Betriebs-SOP §6/§11).
- Health-Checks, Stichproben, verstärktes Monitoring in den Folgetagen.
- Konten wieder freischalten, sobald sicher.

4.6 Nachbereitung (Post-Incident)

- **Datenschutz-Bewertung:** Waren Personendaten betroffen? → Meldepflicht prüfen. **DSGVO: 72 Std.** an Aufsichtsbehörde bei Risiko; Betroffene ggf. informieren (siehe SOP Datenschutz).
- Post-Mortem: Zeitleiste, Ursache, Wirkung, Sofort- und Dauermaßnahmen.
- Lessons Learned in SOPs/Monitoring einarbeiten.

5. Präventive Härtung (Referenz)

- Starke, einzigartige Secrets in `.env`; Default-Passwörter (`timetracking123`, `admin123`) vor Produktion ändern.
- `NODE_ENV=production`, HTTPS/Reverse Proxy, korrektes `CORS_ORIGIN`.

- DB-Port nur intern; regelmäßige Basisimage-Updates.
- Regelmäßige Zugriffs-Rezertifizierung; Audit-Log-Auswertung.

6. Referenzen

- [docs/security.md](#), [docs/SECURITY-FIX-2025-12-29.md](#), [docs/SECURITY-FIX-2025-12-30.md](#)
- [docs/serverpulse-security.md](#)
- SOP Datenschutz, SOP Benutzer- & Zugriffsverwaltung, Betriebs-SOP